

CYBERSECURITY FOUNDATIONS — AFTERNOON WORKSHOP

Building a Security Governance & IAM Program

Applying the concepts from Lesson 1 (Identity and Access Management) and Lesson 2 (Foundations of Security Governance)

Workshop Overview

This afternoon you'll act as a newly hired governance and security consulting team, brought in to design a security governance and Identity and Access Management (IAM) program for a fictional company. You'll apply everything from this morning's two lessons - governance frameworks, roles and responsibilities, the policy documentation hierarchy, and IAM principles like least privilege, RBAC, ABAC, MFA, the identity lifecycle, and directory services.

Midway through the workshop, your instructor will introduce a new development at your company. Be ready to adapt — real governance programs get tested by real incidents.

What You'll Produce

- A governance framework recommendation with justification
- A roles and responsibilities table for your company's security leadership
- One example each of a Policy, Standard, Guideline, and Procedure
- An access control matrix applying least privilege, RBAC, and ABAC
- An identity lifecycle plan for a specific role at your company
- Authentication and authorization examples specific to your systems
- A recommendation on IdP, SSO, federation, and directory services
- A written response to a mid-workshop incident
- An “security pitch” presentation of your program to leadership.

Submission Checklist

- Company brief selected and team roles assigned
- Part 1: Framework justification, roles table, and mission statement complete
- Part 2: One Policy, one Standard, one Guideline, and one Procedure drafted
- Part 3: Access matrix, lifecycle plan, auth examples, and tool recommendations complete
- Part 4: Incident reflection completed after the curveball is revealed

Your Company

Ferrovia Logistics

Supply Chain & Logistics — Regional Freight Network

Ferrovia Logistics operates a regional freight and warehousing network, tracking shipments with GPS-enabled trucks and IoT sensors across five distribution centers. The company employs a small core staff of dispatchers, warehouse managers, and IT administrators, but relies heavily on seasonal warehouse workers and contract drivers, some of whom work for only a few weeks during peak shipping season. Drivers use a mobile routing app that shows customer delivery addresses and package contents; warehouse staff badge into facilities and log into inventory systems. Ferrovia's IT team maintains an on-premises Active Directory environment alongside several newer cloud tools adopted during rapid expansion. After a recent internal audit, leadership discovered that several former seasonal employees still had active system accounts months after their last shift — and they want that fixed for good.

Part 1 — Governance Foundation

COVERS LESSON 1, OBJECTIVES 1–3

Task 1.1 — Select a Governance Framework

Choose the framework — NIST CSF, ISO/IEC 27001, COBIT, or a blend of more than one — that best fits your company's needs. Write 3–5 sentences justifying your choice using specific facts from your company brief.

Your Framework Choice & Justification

Task 1.2 — Governance Roles

Assign a name or title at your company to each governance role below, and list two responsibilities specific to your company's situation.

Role	Name / Title at Your Company	Two Responsibilities (specific to your company)
CISO		
Security Team		
Compliance Officer		
Business Leader		

Task 1.3 — Governance Mission Statement

In 2–3 sentences, write a mission statement explaining why security governance matters at your company.

Mission Statement

Part 2 — Documentation Hierarchy

COVERS LESSON 1, OBJECTIVE 4

Draft one real example of each document type below, tied to an actual pain point mentioned in your company brief. Remember: policies set direction, standards enforce specific rules, guidelines offer flexible advice, and procedures spell out exact steps.

Document Type	Title	Content (2–4 sentences)	Who Approves / Uses It
Policy			
Standard			
Guideline			
Procedure			

Part 3 — IAM Program Design

COVERS LESSON 2, OBJECTIVES 1–5

Task 3.1 — Access Control Matrix

List five roles or positions at your company. For each, decide what systems or data they need, their access level, and whether RBAC or ABAC fits best. At least one row must use ABAC — include a specific condition (time, device, or location).

Role / Position	System or Data Needed	Access Level	RBAC or ABAC?	Justification

Task 3.2 — Identity Lifecycle Plan

Choose one high-turnover or high-risk role from your company brief (for example: a seasonal warehouse worker). Describe what happens to that role's access at each stage of the identity lifecycle.

Stage	What Happens for This Role	Who Is Responsible
Onboarding		
Active Use / Review		
Offboarding		

Task 3.3 — Authentication vs. Authorization

Give one concrete example of each, specific to your company's systems.

Authentication Example (“Who are you?”)

Authorization Example (“What can you access?”)

Task 3.4 — IdP, SSO & Federation Recommendation

Should your company use an Identity Provider and Single Sign-On? Should it federate identity with any outside partners (contractors, agents, vendors)? Justify your recommendation.

Recommendation & Justification

Task 3.5 — Directory Services Decision

Would your company be best served by Active Directory, LDAP, a cloud directory, or a hybrid approach? Justify in 2–3 sentences.

Directory Services Decision & Justification

Task 3.6 — MFA Policy

Identify at least three systems or access points at your company and specify whether MFA is required and which factors you'd use.

System / Access Point	MFA Required? (Y/N)	Which Factors?

Part 4 — Curveball: Incident Response

APPLIES LESSONS 1 & 2 TOGETHER

WAIT FOR YOUR INSTRUCTOR

Do not fill out this page yet. At the designated time, your instructor will share a short update describing something that just happened at your company. Read it carefully as a team, discuss for a few minutes, then complete the reflection below.

Incident Reflection

1. Summarize the incident in your own words.

Summary

2. What governance or IAM gap most likely enabled this?

Gap

3. Which existing policy, standard, or procedure from Part 2 should be invoked — or does a new one need to be created?

Response

4. What immediate access changes would your team make?

Access Changes

5. Who should be notified, and in what order? Use your Part 1 roles table.

Notification Order

Part 5 — Present Your Program

Present your “security pitch”. Cover:

- Your framework choice and why it fits your company
- One example from your documentation hierarchy (policy, standard, guideline, or procedure)
- A highlight from your access control matrix, including your RBAC vs. ABAC reasoning
- How your team responded to the curveball incident

Grading Rubric (100 Points)- Scale 4

Part 1 — Governance Foundation (25 pts)

Part 2 — Documentation Hierarchy (20 pts)

Part 3 — IAM Program Design (40 pts)

Part 4 — Curveball Response (15 pts)